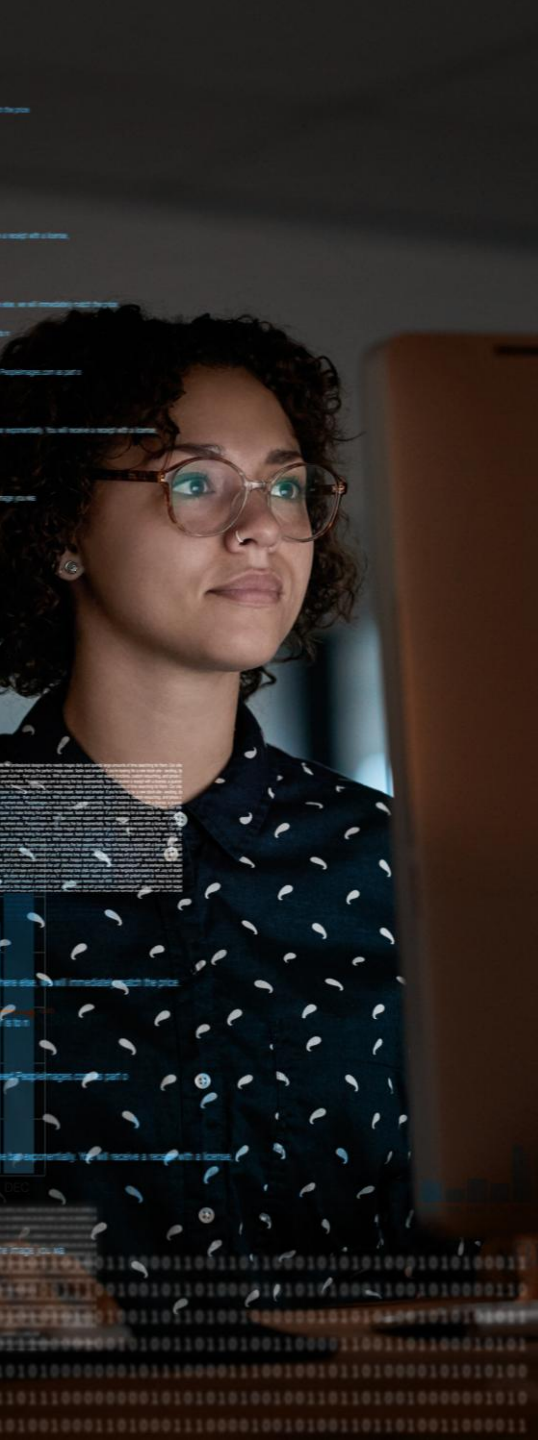




# CISSP Exam Tips Bootcamp

**Michael J Shannon**

CISSP, CCSP, CCSK

SecurityX

ITIL 4 Managing Professional

Class will begin at 10:00 am  
Central Standard Time

# The CISSP Exam Registration Process (2026)

- **Create an ISC2 Account**
  - You must create an account at ISC2.org to manage your exam registration, endorsement, and certification status
- **Register Through Pearson VUE**
  - Selecting a test center or online proctored option (if available in your region)
  - Agreeing to ISC2 exam policies and the Candidate agreement
  - Paying the exam fee (typically around \$749 USD, subject to regional variation)



# Exam Format (2026)

- Computer Adaptive Testing (CAT) for most regions
  - ISC2's CAT technology dynamically adjusts question difficulty in real time based on how well you are performing, selecting each next item to pinpoint your true ability level
  - This approach shortens the exam, increases precision, and enhances security by generating a unique, adaptive question path for every test-taker
- 100-150 questions in 3 hours maximum
- A mix of multiple choice and advanced innovative items
- Domains are weighted according to the current outline



# CISSP Domain Weightings

| Domain                                   | Weight |
|------------------------------------------|--------|
| 1. Security and Risk Management          | 16%    |
| 2. Asset Security                        | 10%    |
| 3. Security Architecture and Engineering | 13%    |
| 4. Communication and Network Security    | 13%    |
| 5. Identity and Access Management (IAM)  | 13%    |
| 6. Security Assessment and Testing       | 12%    |
| 7. Security Operations                   | 13%    |
| 8. Software Development Security         | 10%    |



# Summary of “How To Think Like A Manager for the CISSP Exam” by Luke Ahmed

- The book is widely recommended because it reframes CISSP study from memorizing facts to thinking like a security manager, which is the mindset expected on the exam
- It also distills complex governance and risk concepts into clear, practical decision-making patterns that help readers answer scenario questions with confidence

# Think at the Policy Level, Not the Keyboard Level

- CISSP questions expect you to prioritize policies, governance, and organizational impact over technical fixes
- A manager focuses on why something matters, not just how it works
- Decisions must align with business goals, regulatory requirements, and risk tolerance



# Think at the Policy Level, Not the Keyboard Level

- Technical solutions are evaluated through the lens of cost, risk, and long-term sustainability
- **The correct answer is usually the one that protects the organization's mission, not the one that solves a technical detail fastest**
- Always elevate your thinking to strategy, oversight, and accountability





# Prioritize People and Processes Before Technology

- Managers understand that humans and workflows create most vulnerabilities and most opportunities for improvement
- Technology is only effective when supported by training, procedures, and governance
- **CISSP questions often reward answers that strengthen awareness, documentation, and communication**



# Prioritize People and Processes Before Technology

- Process failures frequently cause incidents long before a technical flaw is exploited
- Strengthening human behavior and organizational discipline reduces risk more effectively than buying new tools
- **Choose answers that reinforce culture, clarity, and consistency**



# Risk Management Drives Every Decision

- Managers evaluate threats, vulnerabilities, and impacts before choosing a control
- **CISSP questions expect you to reduce risk to an acceptable level, not eliminate it entirely**
- The “best” answer is the one that aligns with the organization’s risk appetite and budget



# Risk Management Drives Every Decision

- Risk assessments, risk registers, and mitigation strategies are central to managerial thinking
- Controls must be justified by measurable reductions in likelihood or impact
- **Always think in terms of prioritization, proportionality, and business justification**

# Choose Preventive Controls Before Detective or Corrective

- Preventive controls stop incidents before they occur, making them the most valuable from a managerial perspective
- **CISSP questions often reward answers that reduce exposure rather than detect or respond after damage**
- Preventive measures include policies, training, access controls, and secure design



# Choose Preventive Controls Before Detective or Corrective

- Detective controls are important but secondary because they only alert you after something has gone wrong
- Corrective controls help restore operations but do not reduce initial risk
- **When in doubt, choose the answer that prevents harm at the earliest stage (Shift-left mentality)**





# Always Protect Confidentiality, Integrity, and Availability (CIA)

- Managers evaluate which part of the CIA triad is most threatened in a scenario
- **CISSP questions often hinge on identifying the primary security objective at risk**
- Not every situation is about confidentiality; sometimes integrity or availability is the real priority



# Always Protect Confidentiality, Integrity, and Availability (CIA)

- Controls must be selected based on which CIA component needs reinforcement
- Understanding the business context helps determine which element matters most
- **The best answer preserves the organization's ability to operate securely and reliably**

# Documentation, Policies, and Governance Are Your First Line of Defense

- Managers rely on written policies to define expectations, responsibilities, and acceptable behavior
- **CISSP questions frequently reward answers that reference policy creation, review, or enforcement**
- Documentation ensures consistency, accountability, and auditability



# Documentation, Policies, and Governance Are Your First Line of Defense

- Policies guide technical teams and reduce ambiguity during incidents
- Governance frameworks ensure that security decisions support organizational strategy
- Strong documentation is a hallmark of mature security management



# Escalate, Communicate, and Coordinate Before Acting

- Managers do not act impulsively; they follow communication channels and escalation procedures
- **CISSP questions often reward answers that involve notifying leadership or stakeholders before taking action**
- Unauthorized or unilateral action can create legal, operational, or compliance risks



# Escalate, Communicate, and Coordinate Before Acting

- Incident response requires coordination, not improvisation.
- Communication ensures that decisions are aligned with policy and leadership intent.
- **The best answer usually involves informing the right people at the right time**





# Legal, Regulatory, and Compliance Requirements Shape Security Decisions

- Managers must understand how laws and regulations influence acceptable actions
- **CISSP questions often hinge on compliance obligations such as privacy laws, breach notification rules, or industry standards**
- Violating legal requirements can be more damaging than a technical failure



# Legal, Regulatory, and Compliance Requirements Shape Security Decisions

- Compliance drives documentation, reporting, and control selection
- Security decisions must be defensible in audits and investigations
- **The best answer aligns with legal obligations and reduces organizational liability**

# Think Long-Term: Sustainability Over Quick Fixes

- Managers choose solutions that scale, endure, and integrate with existing processes
- **CISSP questions reward answers that emphasize long-term stability rather than short-term convenience**
- Quick fixes often introduce new risks or technical debt



# Think Long-Term: Sustainability Over Quick Fixes

- Sustainable solutions include training, policy updates, and architectural improvements
- Long-term thinking reduces operational friction and improves resilience
- **The best answer supports ongoing security maturity, not temporary relief**





# Security Is a Business Enabler, Not an Obstacle

- Managers frame security as a way to support business goals, not hinder them
- **CISSP questions often reward answers that balance protection with usability and productivity**
- Overly restrictive controls can harm operations and reduce stakeholder buy-in



# Security Is a Business Enabler, Not an Obstacle

- Effective security integrates seamlessly into business processes
- The goal is to reduce risk while enabling innovation and efficiency
- **The best answer supports mission success while maintaining responsible safeguards**

# Sample PBQ 1

A security analyst is responding to a suspected insider-threat incident involving unauthorized access to sensitive financial records. You must match each action to the correct phase of the incident response process.

Actions:

1. Capture volatile memory from the suspect workstation
2. Revoke the user's access and isolate the workstation from the network
3. Perform a root-cause analysis and document lessons learned
4. Restore the workstation from a known-good image and validate system integrity
5. Review logs to confirm whether unauthorized access occurred

# Sample PBQ 1 (continued)

Incident Response Phases:

A. Containment

B. Identification

C. Recovery

D. Lessons Learned

E. Eradication

Answers:

Capture volatile memory → Identification

Revoke access & isolate workstation →  
Containment

Root-cause analysis & documentation →  
Lessons Learned

Restore from known-good image → Recovery

Review logs to confirm unauthorized access →  
Identification

# Sample PBQ2

Your organization has four data types that must be assigned to the correct classification level and matched with the appropriate handling requirement. You are asked to drag-and-drop each data item to the correct classification AND the correct handling rule. Below are the items you must match.

Data Items:

1. Source code for a proprietary trading algorithm
2. Employee home addresses stored in HR systems
3. Marketing brochures intended for potential customers
4. Internal audit findings related to financial controls

# Sample PBQ2 (continued)

## Classification Levels:

- A. Public
- B. Internal Use
- C. Confidential
- D. Highly Confidential

## Handling Requirements:

- Must be encrypted at rest and in transit; access restricted to authorized teams only
- May be shared externally without restriction
- Must be stored on internal systems only; no external sharing
- Must be protected due to privacy regulations; access limited to HR personnel

# Sample PBQ2 Answer

1. Source code for a proprietary trading algorithm

Classification → Highly Confidential, Handling → Must be encrypted at rest and in transit; access restricted to authorized teams only

2. Employee home addresses

Classification → Confidential, Handling → Must be protected due to privacy regulations; access limited to HR personnel

3. Marketing brochures

Classification → Public, Handling → May be shared externally without restriction

4. Internal audit findings

Classification → Internal Use, Handling → Must be stored on internal systems only; no external sharing

# Question 1

Which of the following actions MOST clearly demonstrates effective security governance rather than security management?

- A. Approving the annual vulnerability scanning schedule for all business units
- B. Defining the organization's risk appetite and ensuring security aligns with business objectives
- C. Reviewing daily security operations center (SOC) incident summaries
- D. Selecting the technical controls required to meet a new regulatory requirement

Correct answer: B

The trap is that A and D sound strategic but are operational or tactical. Governance is about direction, oversight, and alignment, not scheduling or selecting controls.

## Question 2

A security architect is evaluating controls for a database that processes sensitive financial records. Which control MOST directly protects the data in use?

- A. Full-disk encryption
- B. TLS for data in transit
- C. Homomorphic encryption or secure enclaves
- D. Database backups stored offsite

Correct answer: C

Full-disk encryption (A) protects data at rest, and TLS (B) protects data in transit. The exam loves this three-way distinction; data in use requires memory-level protections.

# Question 3

A security architect wants to prevent lateral movement between workloads in the same data center while still allowing them to share the same physical infrastructure. Which approach BEST meets this requirement?

- A. VLAN segmentation with shared routing
- B. Microsegmentation using host-based firewalls
- C. Air-gapping the workloads onto separate physical switches
- D. Implementing a single large flat subnet with ACLs at the perimeter

Correct answer: B

The trap is A—VLANs segment but do not isolate; lateral movement is still possible if routing or misconfigurations occur. Microsegmentation enforces per-workload isolation, which is the CISSP-aligned answer.

## Question 4

In a software-defined networking (SDN) architecture, which risk is MOST critical for the security team to address?

- A. Switches forwarding packets based on outdated MAC tables
- B. The controller becoming a single point of compromise for network-wide policy
- C. VLAN hopping attacks between virtual segments
- D. Excessive broadcast traffic overwhelming virtual switches

Correct answer: B

The SDN controller is the centralized brain of the network. If compromised, an attacker can rewrite flows across the entire fabric. The other options are traditional network issues, not SDN-specific.

# Question 5

A company uses WPA2-Enterprise with PEAP-MSCHAPv2 for Wi-Fi authentication. A penetration test shows that attackers can capture challenge-response traffic and attempt offline password cracking. Which improvement MOST effectively reduces this risk?

- A. Switching to WPA2-PSK with a long passphrase
- B. Disabling SSID broadcast
- C. Enforcing certificate-based EAP-TLS authentication
- D. Using MAC filtering to restrict device access

Correct answer: C

PEAP-MSCHAPv2 is vulnerable to offline cracking because MSCHAPv2 relies on weak challenge-response mechanisms.

## Question 6

A hospital needs to ensure that nurses can only access patient records for individuals currently assigned to their unit, and access must change dynamically as assignments shift. Which model BEST satisfies this requirement?

- A. Role-Based Access Control (RBAC)
- B. Mandatory Access Control (MAC)
- C. Attribute-Based Access Control (ABAC)
- D. Discretionary Access Control (DAC)

Correct answer: C

RBAC (A) is too static. The requirement is context-driven, dynamic authorization, which is classic ABAC.

# Question 7

A regional outage forces a company to shift operations to a secondary site. The failover succeeds, but employees are unsure how to continue business processes during the disruption. Which plan MOST clearly failed?

- A. Disaster Recovery Plan (DRP)
- B. Business Continuity Plan (BCP)
- C. Incident Response Plan (IRP)
- D. Crisis Communications Plan

Correct answer: B

DRP restores systems; BCP restores business operations. The systems worked, but the business didn't—classic CISSP distinction.

## Question 8

A developer wants to use production customer data in a test environment to troubleshoot a defect. Access to the test environment is less restricted than production. What is the BEST action?

- A. Allow the request if the test environment is encrypted
- B. Mask or anonymize the data before using it in testing
- C. Permit the request because the developer has production access
- D. Copy only a small subset of production data to reduce exposure

Correct answer: B

CISSP stresses data minimization and masking when moving production data into less-controlled environments.



# Exam Prep Strategies

- Understand the Exam Blueprint
  - Download the official CISSP exam objectives
  - Treat the objectives as a contract. If it is listed, then it's testable
- Establish a Study Framework
  - Choose one primary learning resource (bootcamp)
  - Choose one secondary resource (practice questions)
  - Build a study calendar with daily goals



# Exam Prep Strategies

- You want conceptual mastery before memorizing details – **think like a security manager**
- Begin doing practice questions early
  - Start with untimed practice questions to learn patterns
  - After a week or so shift to timed sets
  - Track the following:
    - Wrong answers
    - Why you missed them
    - What domain they belong to



# Exam Prep Strategies

- Build a Performance-Based Questions (PBQ) strategy realizing that they often include:
  - Drag-and-drop logic
  - Reading logs quickly
  - Identifying “best” vs “correct” answers
- As the exam approaches target the weaker domains
  - Use your practice test analytics to identify:
    - Domains below 80%
    - Topics you consistently miss
    - PBQ types that slow you down



# Exam Prep Strategies

- Do Full-Length Practice Exams preferably more than once before the exam
  - Simulate real exam conditions
  - Use a 3-hour timer
  - No distractions
  - No pausing
  - No notes
- Aim for 85–90% on practice exams before scheduling the real test

# Day of the Exam Strategies

- Don't stay up and cram the night before
- Wake up at the normal time
- Do a light review only or a few questions to get into a security frame of mind
- Manage stress physiology (breathing)
  - No big meal or abnormal fluid intake beforehand
- Arrive early to the testing center
- Use time management – don't stay too long on a question
- Trust your first “gut” instinct if it's a “coin-flip”



# Passing the Exam

- You must score 700 out of 1000
- CAT adjusts difficulty based on your performance
- You receive a provisional pass/fail at the test center

# The Post-Exam Endorsement Process

**Passing the exam does not officially make you a CISSP yet**

- You must complete the ISC2 Endorsement Process within nine months

## **What Endorsement Means**

- An existing ISC2 member (in good standing) must verify:
- Your work experience,
- Your professional conduct,
- Your adherence to the ISC2 Code of Ethics
- If you do not know a member, ISC2 can act as your endorser





# Documentation and Review

**You must submit the following required documentation:**

- Detailed job descriptions for each role,
- Dates of employment,
- Manager or HR contact information,
- Domain mapping showing how your work aligns with CISSP domains

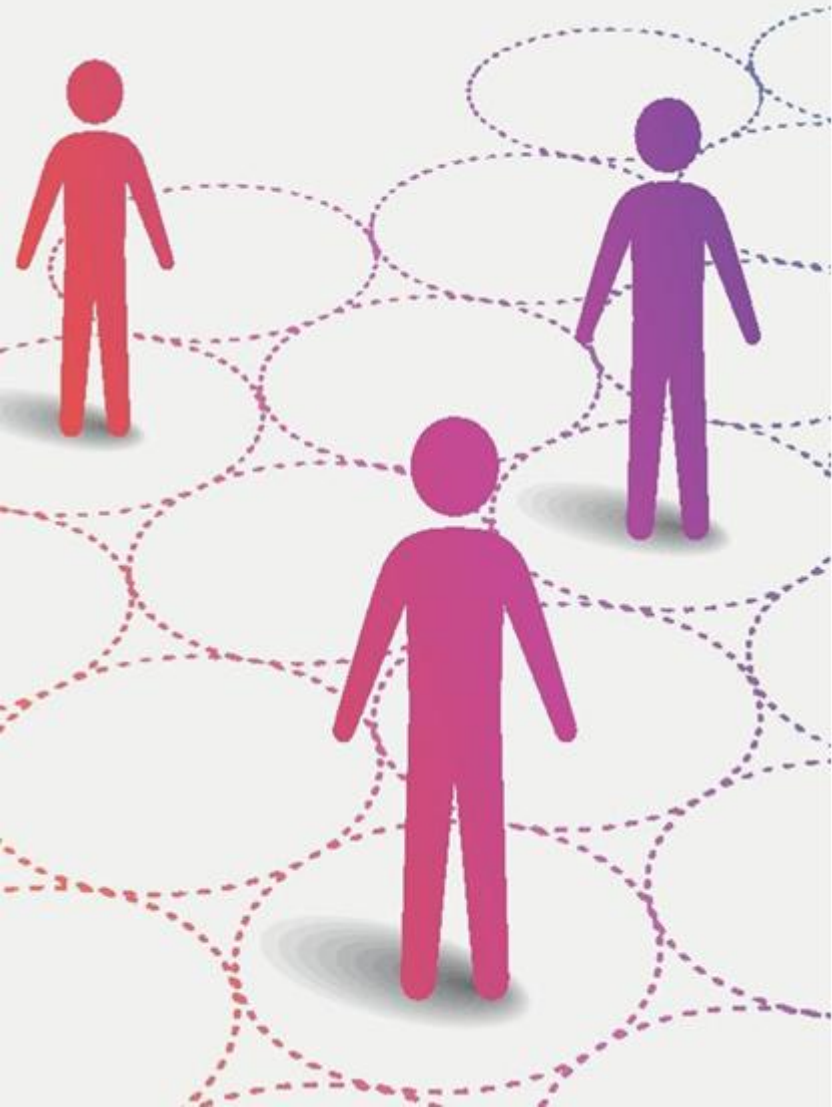
**During ISC2 review process they may:**

- Request additional documentation,
- Contact employers,
- Ask for clarification on domain alignment

**Once approved, you become a CISSP!**

# Practical Tips for Applicants

- Start documenting your experience **before** taking the exam
- Use ISC2's **Experience Assessment Tool** to self-evaluate domain coverage
- Keep HR contacts updated in case ISC2 needs verification
- If you're teaching or building a bootcamp (like I am), track those hours for CPE credit later
- If you're unsure about eligibility, the **Associate of ISC2** path is a safe and strategic option
- Treat the endorsement process like a professional audit—clear, concise, and evidence-based



# Common Mistakes Applicants Make

- Misunderstanding what counts as domain-relevant experience
- Failing to document responsibilities clearly
- Waiting too long to complete endorsement
- Not mapping job duties to CISSP domains
- Assuming job titles alone will satisfy ISC2 reviewers
- Forgetting to maintain CPEs after certification...



# Annual Maintenance (Post Certification)

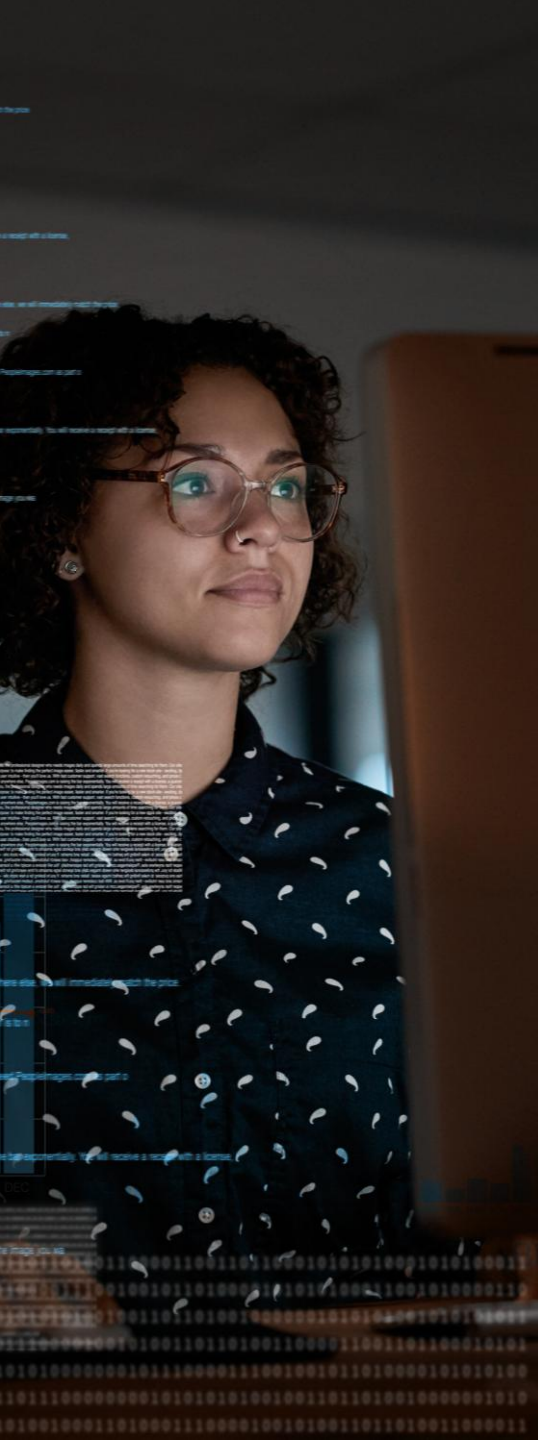
## Annual Maintenance Fee (AMF)

- CISSP AMF is \$135 per year (subject to change)
- Must be paid annually to maintain certification

## Continuing Professional Education (CPE)

- You must earn 120 CPE credits every 3 years, with at least 40 CPEs per year recommended.
- CPEs can come from: training, conferences, webinars, teaching, publishing, and security related work projects





**Thank You  
for  
Attending!**

Michael J Shannon